SECCIÓN 5.4

Análisis de eventos de autenticación e identidad

Temas de esta sección:

- Por qué identidad es tan importante: comprometer una cuenta puede bastar
- Login exitoso ≠ login legítimo · MFA exitoso ≠ no hay compromiso
- Patrones de login fallido: fuerza bruta, spraying, stuffing
- MFA fatigue e impossible travel
- Dispositivos nuevos, reglas de correo y nuevos métodos MFA
- OAuth apps, tokens y consentimientos
- Cuentas privilegiadas y cuentas de servicio

5.4 | Login exitoso ≠ login legítimo

La autenticación responde '¿la cuenta logró iniciar sesión?' No responde '¿la persona autorizó esa acción?'

Un login exitoso con MFA puede ocurrir en estos escenarios:

Phishing avanzado (AiTM)

El usuario ingresó sus credenciales en una página falsa. El atacante usa un proxy para capturar la sesión en tiempo real.

MFA fatigue

El atacante genera tantos prompts que el usuario aprueba uno por cansancio o confusión.

Token robado

El atacante usa el token de sesión sin necesitar la contraseña. Bypasea MFA completamente.

Dispositivo comprometido

El dispositivo del usuario fue el vector. El MFA se aprobó desde ahí.

MFA push approve legítimo confundido

El usuario creyó que la solicitud era suya y la aprobó.

Cuenta compartida

Varios usuarios acceden con las mismas credenciales. Dificulta atribución.

El SOC debe mirar qué ocurrió DESPUÉS del login. El contexto posterior suele ser más importante que el login en sí.

5.4 | Señales de identidad: de evento aislado a secuencia

Un evento de identidad puede ser ambiguo. Una secuencia es mucho más preocupante:

1	Login desde IP extranjera	AMBIGUO	*Puede ser VPN, viaje real o proxy*
2	MFA exitoso	AMBIGUO	*No descarta compromiso*
3	Dispositivo desconocido	SEÑAL	*Aumenta sospecha*
4	Mailbox forwarding rule creada	ALERTA	*Posible exfiltración silenciosa*
5	1,200 archivos de SharePoint descargados	ALTO	*Posible exfiltración de datos*
6	OAuth app consented con Read Mail + Read Files	CRÍTICO	*Persistencia sobre identidad sin contraseña*

Tres patrones distintos de ataque a credenciales — señales diferentes en los logs:

Fuerza bruta

Muchos intentos contra una cuenta.

- Alta cantidad de failed logins para UN usuario
- Desde misma IP o rango de IPs
- Login exitoso al final: señal crítica
- Puede generar Account Lockout

⚠ SOC: correlacionar login exitoso final con actividad posterior.

Password Spraying

Pocas passwords en muchas cuentas para evitar lockout.

- 1-2 intentos fallidos en MUCHAS cuentas
- Mismo horario para todas
- Difícil de ver por cuenta individual
- Requiere correlación cross-account

⚠ SOC: buscar patrón en SIEM: muchas cuentas, pocos intentos, mismo bloque de tiempo.

Credential Stuffing

Usa listas de usuario:password filtradas de otros breaches.

- Intentos en muchas cuentas distintas
- Éxitos dispersos, no consecutivos
- IPs rotando, user-agents de herramienta
- Correlacionar con fuentes de Threat Intel

⚠ SOC: comparar cuentas afectadas con bases de credentials expuestos.

5.4 | MFA fatigue, impossible travel y regla de correo

Tres señales de identidad que requieren análisis de actividad posterior:

MFA FATIGUE

```
User: finanzas.martin
MFA prompts: 12  |  Denied: 11
Approved: 1
Source IP: Foreign IP
Time: 01:20 AM
```

El atacante genera muchos prompts hasta que el usuario aprueba uno por cansancio. Validar: cantidad de prompts, ubicación, dispositivo, actividad posterior.

→ Escalar. Confirmar con usuario.

IMPOSSIBLE TRAVEL

```
Login 1: Buenos Aires - 09:05
Login 2: Madrid - 09:22
User: legal.romero
MFA: Success  |  Device: Unknown
```

Señal relevante pero no confirma compromiso. Puede ser VPN, proxy, geolocalización incorrecta. Lo importante es la actividad posterior.

→ Revisar actividad siguiente.

REGLA DE CORREO

```
User: legal.romero
Rule: Forward all to
  externalmail123@gmail.com
Created after: login foreign IP
```

Puede indicar exfiltración silenciosa o persistencia. La regla continúa enviando info aunque el atacante pierda acceso.

→ Escalar. Revocar regla.

Una OAuth app consented puede mantener acceso sin contraseña, aún después de resetear credenciales:

Qué es y cómo funciona

OAuth permite que una app de terceros acceda a recursos (correo, archivos, calendario) sin necesitar la contraseña del usuario.

El usuario otorga consentimiento → la app recibe un token → puede acceder mientras el token sea válido.

Señales en SOC:
- OAuth app consent desde IP extranjera
- App con permisos Read Mail + Read Files
- App desconocida o con nombre genérico
- Creada después de login anómalo
- Token activo aunque se reseteó la contraseña

Qué revisar y cómo responder

Para investigar:
- ¿Quién consintió la app y cuándo?
- ¿Qué permisos tiene la app?
- ¿La app es conocida/aprobada?
- ¿Hubo acceso real a datos?
- ¿El consentimiento coincide con login anómalo?

Para responder:
- Revocar el consentimiento de la app
- Revisar tokens activos asociados
- Revisar actividad realizada con el token
- Resetear contraseña NO es suficiente solo

⚠ **Reseteando la contraseña NO se invalida el token de OAuth. La revocación del acceso debe hacerse explícitamente.**

Dos tipos de cuentas con riesgo elevado y señales distintas:

Cuentas privilegiadas

Administradores de dominio, de sistemas o de seguridad.

Señales de alerta:
- Login desde notebook de usuario (no workstation admin)
- Acceso fuera de horario sin ticket
- Acceso a múltiples servidores en minutos
- Actividad en DC o activos críticos
- Creación de servicios remotos

Prioridad: SIEMPRE alta. El compromiso de una cuenta privilegiada puede afectar toda la organización.

Cuentas de servicio

Cuentas que ejecutan procesos automatizados: backups, monitoreo, despliegues.

Señales de alerta:
- Login interactivo (no debería loguear interactivamente)
- Ejecución de comandos ad hoc
- Acceso a sistemas fuera de su alcance normal
- Movimiento lateral desde su host habitual
- Actividad en horarios que no corresponden al job

Nota: svc_backup ejecutando vssadmin delete shadows = señal crítica de posible ransomware.

Cuentas privilegiadas comprometidas requieren escalamiento inmediato, independientemente de la evidencia técnica disponible.